

Exploiting Unexploitable XSS

Exploiting Unexploitable XSS - Author not stated, stephensclafani.com.

- Published: date not stated
- Original: <<http://stephensclafani.com/2009/05/26/exploiting-unexploitable-xss/>>
- Preserved from: <http://stephensclafani.com/2009/05/26/exploiting-unexploitable-xss/> (stored) on 2026-08-06
- Capture timestamp: 20160427123221
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Exploiting Unexploitable XSS

Exploiting Unexploitable XSS

May 26th, 2009

XSS that are protected by CSRF protection or where other mitigating factors are present are usually considered to be unexploitable or of limited exploitability. This post details real world examples of exploiting "unexploitable" XSS in Google and Twitter. While the XSS detailed in this post are site specific the methods that were used to exploit them could be applied to other websites with similar implementations. Alex's (kuza55) [Exploiting CSRF Protected XSS](#) served as inspiration for this post.

Google

Google has services deployed across many different domains and subdomains and as a result requires a way to seamlessly authenticate members who are logged in to their Google Account. Google's solution to this problem is the ServiceLogin URL.

```
https://www.google.com/accounts/ServiceLogin?
service=service&continue=https%3A%2F%2Fwww.service.com%2Fstart&passive=true&go=true&alinsu=1&apli
insu=1&alwf=true&skipvpage=true&rm=false&showra=1&fpui=2&naui=8
```

When called by a member who is logged in to their Google Account the URL generates an auth URL and redirects to the particular service.

```
https://www.service.com/start?
pli=1&auth=DQAAAIMAAABROiyjL2nUD6sZ40mV0Xw1XwzfVn_T9nrBQqka1GYz2zPVQBDwxnAQebLKo6R0bLpWBTnfh_Xz1
pwjKvEljf7Ui0S-
```

jS4eg9jWPv13NJBuOcJw1Fc3W5PaIA9EWrdbpT41RtxL8PDs7KQKNxFXyAi6LkPG1XyMqcyFWREAuOF7RnV7Eo8Arv8aYvVvYuLT1tg

When the auth URL is loaded the service uses the auth token to log the member in. No verification was done between the service and Google to ensure that the account that the member was being logged in to was actually theirs. It was possible, then for an attacker to generate an auth URL for their account at a service and to use it to log a member in without affecting the member's Google Account session. Because the member's Google Account session was untouched it was also possible for the attacker to use the ServiceLogin URL to log the member back into their own account at the service.

[[image: Google Sites XSS]](<http://stephensclafani.com/wp-content/uploads/2009/05/googlesites.png>)

On the Google Sites User Settings page a user's settings were used in a javascript function unsanitized. As a result, it was possible for an attacker to submit a setting with a value that would break out of the function and inject javascript into the page. Since the User Settings form is protected against CSRF, this was a self-only XSS. However, with the ability to log a member into an account and back into their own account the attacker could exploit this issue as if it was a full blown reflected XSS.

[[image: Blogger XSS]](<http://stephensclafani.com/wp-content/uploads/2009/05/blogger.png>)

On the Advanced Settings page for publishing a Blogger blog on a custom domain a javascript function takes the value of the "Your Domain" field and displays it in the "Use a missing files host?" section. This function would display the value unsanitized. If the Advanced Settings form is submitted with javascript as the domain an invalid domain error is returned. On the error page the function is executed on page load which would result in the javascript being reflected on the page. Blogger's forms are protected against CSRF, however like with the bad domain error message, the error message for using a bad CSRF token is displayed along with the XSS on the error page. This XSS was limited, however, in that to make a successful POST a blog ID belonging to the current logged in member is required. An attacker would have to hard code their exploit for a specific target blog otherwise the POST would be redirected to a login page. The attacker could get around this limitation, however, by logging a member into an account that they had created with a known blog ID which could then be used in the POST to trigger the XSS.

The XSS in Blogger was made easier to exploit due to the error message for using a bad CSRF token being displayed on the same page as the XSS. When the error message is properly displayed on a separate page, reflected XSS that require a POST and are protected by CSRF protection are considered to be unexploitable since it should be impossible for an attacker to know the CSRF token. However, this is not always the case. The implementation of many sites CSRF protection, including the majority of Google services, tie the CSRF token to a member's account but not to an account's specific session. Making the token compatible across sessions of the same account. With the ability to log a member into an account and to predict the CSRF token for the account, it becomes possible for an attacker to exploit these XSS as if they were unprotected.

[[image: YouTube XSS]](<http://stephensclafani.com/wp-content/uploads/2009/05/youtube.png>)

At ads.youtube.com a YouTube member can create paid promotions for their videos. A promotion consists of a frame from the video and three lines of text. On the second step of the promotion creation process, the "Write your Promotion" page, a member is given three frames from their video to choose from and three text fields to enter their three lines of text. When the form is submitted, if the text fields contain invalid characters such as html/javascript an error is returned. On the error page the value of the

first text field was used unsanitized in the title and alt attributes of the promotion's image. YouTube's forms are protected against CSRF and the error message for using a bad CSRF token is displayed on its own page. However, because YouTube's CSRF tokens are compatible across sessions of the same account, it was possible for an attacker to exploit this XSS by logging a member into an account that they control.

Since being notified of these XSS Google has fixed the issues. Google has also started deploying protection to prevent the exploitation of auth URLs. The protection has already been deployed at Gmail and Google is looking to extend it to other services.

Twitter

(<http://stephensclafani.com/wp-content/uploads/2009/05/twitter.png>)

On every Twitter page a member's language preference is used as a variable in the Google Analytics code. For members who had not yet set a language preference it was possible for an attacker to set it temporarily by using the URL:

```
http://twitter.com/?lang=
```

The value would be used in the Google Analytics code unsanitized.

Since setting any of the profile settings also sets a language preference, and since settings their profile settings is the first thing most Twitter members do after registering, very few members would have been vulnerable to this XSS.

Twitter, like many sites that have implemented CSRF protection, did not extend the protection to its login page, allowing login CSRF attacks. With a login CSRF attack it would have been possible for an attacker to exploit the XSS by first logging a member into an account that had not yet had its language preference set. However, since using login CSRF destroys a member's session, this attack would have had limited exploitability.

Twitter has a "Remember me" feature on its login page that when used will remember a member's session after they have shut down their browser. Different sites implement this feature in different ways. Some sites set the same session cookies but make them persistent if the feature is used, other sites such as Twitter set a unique persistent cookie in addition to the session cookie. If an attacker used a login CSRF attack against a member who had logged in to Twitter using the "Remember me" feature, and in the attack the feature was unused, the member's session would be overwritten but their "Remember me" cookie would not be. The attacker could then exploit the XSS and either steal the cookie or use it to log the member back into their own account and continue with the attack.

Since being notified of the XSS Twitter has fixed the issue and has extend its CSRF protection to its login page.